

1. (14 points) Classify each of the following as a violation of confidentiality, of integrity, of availability, or of some combination thereof.
 - a. John copies Mary's homework.
 - Confidentiality: In order for John to copy Mary's homework, he must have unauthorized access to view it.
 - Integrity: This violates origin integrity as John claims he is the source of the information, but the source is in fact Mary.
 - b. Paul crashes Linda's system
 - Availability: The system is unable to be used, so Linda does not have access to her own resources.
 - c. Carol changes the amount of Angelo's check from 100 to 1,000.
 - Integrity: The original amount was altered by someone with unauthorized access, meaning that the information is no longer accurate or trustworthy.
 - d. Gina forges Roger's signature on a deed.
 - Integrity: Gina is falsely posing as Roger, so the deed's authenticity was compromised.
 - e. Rhonda registers the domain name "Pearson.com" and refuses to let the publishing house buy or use that domain name.
 - Availability: The publishing house is not able to use a resource (the domain name), which is associated with them.
 - f. Jonah obtains Peter's credit card number and has the credit card company cancel the card and replace it with another card bearing a different account number.
 - Confidentiality: Jonah now has access to Peter's private information (credit card number) without authorized permission.
 - Availability: Since Peter's card is cancelled, he can't use any of his financial resources.
 - Integrity: Jonah used the information he obtained to make unauthorized changes to Peter's bank account.
 - g. Henry spoofs Julie's IP address to gain access to her computer.
 - Integrity: The information used to identify Julie during network communication is false, so Henry is posing as Julie.
 - Confidentiality: Henry has unauthorized access to Julie's system.
2. (16 points) The aphorism "security through obscurity" suggests that hiding information provides some level of security. Give an example of a situation in which hiding information does not add appreciably to the security of a system. Then give an example of a situation in which it does.

Answer: An example of obscurity does not do much for security is if you hide a login page on a secret URL. Though this makes it more difficult for an attacker to find, the

attacker may still be able to find it if they scan the website. So in this way, obscurity does not protect much, you must implement vicarious layers of security. On the other hand, sending a password reset link where the token is very long and random makes a marked difference in security. Even if an attacker had a good idea of how the system works, it is very unlikely that they would be able to guess a valid token. So in this case, obscurity does a fairly good job of enforcing security.

3. (20 points) The PostScript language describes page layout for printers. Among its features is the ability to request that the interpreter execute commands on the host system.
- a. Describe a danger that this feature presents when the language interpreter is running with administrative or root privileges.

Answer: If the system were to run a malicious file, the interpreter may execute harmful commands like deleting files or giving an attacker more control of the system since it has administrative privileges.

- b. Explain how the principle of least privilege could be used to ameliorate this danger.

Answer: If the default privilege level were set to the lowest level where the interpreter only has limited permissions, then the interpreter would not be able to affect much. If an attacker ran the same malicious file and the interpreter executed harmful commands, then only a small part of the system would be affected, as opposed to the attacker gaining full control of the system.

4. (30 points) Compare the principles of secure design with the principles of privacy by design. Where do they overlap, and how do they differ?

Answer:

Fail-safe defaults and privacy as the default overlap quite a bit. Both ideas believe in setting their default configurations at the highest level of safety. A design that is secure does not allow access unless explicitly permitted by authorized personnel. Privacy by design states that maximum privacy protection is enabled unless the user opts out. In both cases, the user is not doing any of the work to protect themselves, it is built into both designs.

Open design and visibility also strongly overlap in their rejection of using only obscurity to implement security/privacy. A secure design must be able to be openly viewed while privacy by design states that similarly requires a level of transparency so that users can check that protections are performing their functions properly.

Economy of mechanism and privacy-embedded designs form another point of overlap. Both place emphasis on incorporating privacy throughout the process rather than

simply adding it as an afterthought. Secure designs utilize simplicity to ensure systems are easily audited and understood. Privacy by design requires privacy to be considered at every step of the process and, thus, they both reject “tacking on” privacy.

End-to-end security and complete mediation also overlap. Both include the idea that every access at every point must be checked such that it is not assumed that any previous permissions granted are still valid.

Least common mechanism and privacy embedding overlap in the sense that embedding privacy promotes not sharing data unless necessary. This connects to the secure design idea of least common mechanisms where you minimize shared mechanisms to keep information flowing in the appropriate channels. Both ideas limit the pathways through which information travels to prevent information leaks.

As for differences, secure design focuses on protecting the system and the resources of the system from access that may not be authorized while privacy by design centers around protecting the individual users and their data from exposure. In the secure by design principles, they seem to be created with external attackers in mind, as well as insider threats and system failures. On the other hand, the privacy by design principles seem designed to deal with both external threats and the *misuse* of data by the system. Another important point is that secure by design favors denying access and restricting capabilities. The scope seems to be technical architecture and access controls. Privacy by design tries to minimize collection and maximize user control. Privacy by design scope seems to be technical architecture as well, but with aspects of procedural practices as well.

5. (20 points) The story “Diabologic” by Eric Frank Russell Download “Diabologic” by Eric Frank Russell presents an explorer making first contact with an alien race. That race thinks very logically. He proceeds to confound them.
- a. Why can the newly-contacted race not cope with the explorer’s tactics?

Answer: They are operating on practices and traditions that have allowed them to survive and evolve. They only understand their own line of “logic” and expect/assume others to do the same. So when the explorer employs irrational and contradictory behavior, they are unsure of how to respond.

- b. What key theme of this story relates to attacking or defending a computer system, and how does it do so?

Answer: If a system is built using only predictable, rigid logic, then it may be unable to deal with any unexpected behavior. In relation to cybersecurity, this is a concern as attackers can use deceptive or unusual tactics to gain access to a system. This is because

the system may not anticipate having to handle irrational behavior like nonsense inputs, so those designing the system should be aware and account for such things.